

ĐẠI HỌC BÁCH KHOA HÀ NỘI
TRƯỜNG CÔNG NGHỆ THÔNG TIN & TRUYỀN
THÔNG



Báo Cáo Bài Tập Lớn

Đề tài: **Hạ Tầng Khóa Công Khai (Public Key
Infrastructure – PKI)**

Học phần: **Nhập môn An toàn thông tin –
IT4015**

Mã học phần: IT4015 - Mã lớp: 167834

Giảng viên hướng dẫn: PGS. TS. Nguyễn Linh Giang

Nhóm sinh viên thực hiện: Đỗ Trường Giang 20235066

Hoàng Minh Khôi 20230042

Phạm Gia Hưng 20230036

Nguyễn Thanh Tú 20230075

Hà Nội, June 5, 2026

Contents

1	Giới thiệu	1
1.1	Vấn đề đặt ra	1
1.2	Phạm vi và bố cục báo cáo	1
2	Nền tảng mật mã khóa công khai	2
2.1	Mật mã đối xứng và hạn chế	2
2.2	Mật mã khóa công khai	2
2.3	Tại sao mật mã bất đối xứng chưa đủ	2
3	Cấu trúc hạ tầng khóa công khai PKI	3
3.1	Các mô hình phân phối khóa công khai	3
3.1.1	Bài toán phân phối khóa công khai	3
3.1.2	Public Announcement	3
3.1.3	Host-based Trust	4
3.1.4	Web of Trust (PGP)	4
3.1.5	Hierarchical PKI	4
3.1.6	So sánh trade-off	4
3.2	Định nghĩa và mục tiêu PKI	5
3.3	Các thành phần PKI	6
3.4	Chu kỳ sống của chứng chỉ	8
4	Chứng chỉ số và các chuẩn	10
4.1	Chứng chỉ số X.509	10
4.2	Certificate Signing Request (CSR)	10
4.3	Phân loại chứng chỉ	10
4.4	Các chuẩn PKCS	10
4.5	RFC và chuẩn quan trọng	10
5	Triển khai và ứng dụng thực tế	11
5.1	HTTPS / TLS	11
5.2	Chữ ký số văn bản điện tử	11
5.3	S/MIME – Email bảo mật	11

5.4	VPN và IPSec	11
5.5	Code Signing	11
5.6	PKI trong eGovernment Việt Nam	11
6	Các hệ thống PKI mã nguồn mở	12
6.1	OpenSSL	12
6.2	EJBCA	12
6.3	Let's Encrypt và Certbot	12
6.4	Các công cụ và nền tảng khác	12
7	Thách thức và xu hướng	13
7.1	Thách thức hiện tại	13
7.2	Xu hướng mới	13
8	Kết luận	14
8.1	Tổng kết	14
8.2	Ý nghĩa và triển vọng	14
	Tài liệu tham khảo	15

List of Figures

3.1	Quy trình tạo và xác thực chữ ký số sử dụng cặp khóa công khai và bí mật.	6
3.2	Sơ đồ chu kỳ sống của chứng chỉ số trong hệ thống PKI	9

List of Tables

3.1	So sánh các mô hình tin cậy (Trust Models)	5
3.2	So sánh các phương pháp kiểm tra trạng thái thu hồi chứng chỉ	7

Chapter 1

Giới thiệu

1.1 Vấn đề đặt ra

1.2 Phạm vi và bố cục báo cáo

Chapter 2

Nền tảng mật mã khóa công khai

2.1 Mật mã đối xứng và hạn chế

Nguyên lý mật mã đối xứng

Bài toán phân phối khóa

Giải pháp KDC và giới hạn

2.2 Mật mã khóa công khai

Cặp khóa bất đối xứng và trapdoor function

Thuật toán RSA

Trao đổi khóa Diffie-Hellman

Sơ đồ chữ ký số

2.3 Tại sao mật mã bất đối xứng chưa đủ

MITM attack trên raw public key

Vấn đề ràng buộc danh tính

Chapter 3

Cấu trúc hạ tầng khóa công khai PKI

Hạ tầng khóa công khai (Public Key Infrastructure - PKI) thường bị nhầm tưởng chỉ là một tập hợp các thuật toán mã hóa và phần mềm. Tuy nhiên, trên thực tế, PKI là một hệ thống toàn diện, là sự tổ hợp chặt chẽ giữa con người, quy trình, phần mềm, phần cứng và các chính sách an toàn thông tin. Mục tiêu cốt lõi của hệ thống này là tạo ra, quản lý, phân phối, sử dụng, lưu trữ và thu hồi các chứng chỉ số một cách an toàn, từ đó thiết lập và duy trì nền tảng tin cậy cho các giao dịch điện tử trên môi trường mạng không an toàn.

3.1 Các mô hình phân phối khóa công khai

Sự phát triển của các cơ chế phân phối khóa công khai trải qua nhiều giai đoạn tiến hóa, từ các phương pháp thủ công, đơn giản như Host-based Trust, phân tán như Web of Trust, cho đến các mô hình có tính hệ thống cao như Hierarchical PKI. Mỗi mô hình ra đời nhằm giải quyết những hạn chế của mô hình trước đó, nhưng đồng thời cũng phải đối mặt với những thách thức mới.

3.1.1 Bài toán phân phối khóa công khai

Trong hệ mật mã bất đối xứng, khóa công khai (Public Key) được thiết kế để công bố rộng rãi cho bất kỳ ai muốn giao tiếp an toàn với chủ sở hữu của nó. Tuy nhiên, bài toán đặt ra là làm thế nào để phân phối khóa công khai này rộng rãi mà vẫn đảm bảo tính an toàn. Quá trình phân phối này cần hướng tới việc hỗ trợ bốn mục tiêu an toàn thông tin cơ bản: tính xác thực (Authentication), tính bảo mật (Confidentiality), tính toàn vẹn (Integrity) và tính chống chối bỏ (Non-repudiation).

3.1.2 Public Announcement

Đây là phương pháp cơ bản nhất, trong đó khóa công khai được chia sẻ công khai trên một nền tảng dễ tiếp cận. Một ví dụ tiêu biểu là DNSSEC, nơi khóa công khai được lưu

trữ trực tiếp trong các bản ghi DNS và bất kỳ ai cũng có thể truy vấn thông qua các công cụ như `dig`. Tuy nhiên, điểm yếu lớn nhất của phương pháp này nằm ở khả năng xác thực (Authentication). Khi nhận được một khóa công khai, người dùng không có cơ chế đáng tin cậy nào để kiểm chứng xem khóa đó có thực sự thuộc về thực thể mà nó tự nhận hay không, dẫn đến rủi ro cao về các cuộc tấn công trung gian (Man-in-the-Middle).

3.1.3 Host-based Trust

Mô hình này dựa trên việc thiết lập sự tin cậy thủ công giữa các thiết bị. Điển hình là cơ chế của SSH, sử dụng tệp `known_hosts` để mỗi máy tính tự lưu trữ và quản lý danh sách các khóa công khai mà nó cho là an toàn. Mặc dù hiệu quả trong các hệ thống nhỏ, nhưng khi số lượng thiết bị tăng lên, số lượng kết nối tin cậy cần thiết lập sẽ tăng theo cấp số nhân ($O(n^2)$ cho n máy tính). Điều này khiến mô hình Host-based Trust hoàn toàn thiếu khả năng mở rộng (scalability) và không thể áp dụng cho mạng Internet toàn cầu.

3.1.4 Web of Trust (PGP)

Để khắc phục tính tập trung, Web of Trust (WoT) được giới thiệu trong các hệ thống như PGP (Pretty Good Privacy) [1]. Đây là một mô hình phi tập trung, dựa trên sự xác nhận lẫn nhau (peer endorsement) giữa các người dùng; mỗi cá nhân tự chịu trách nhiệm quyết định mức độ tin cậy đối với khóa của người khác dựa trên các chữ ký xác nhận của bạn bè hoặc đối tác. Dù rất dân chủ và phù hợp cho các cộng đồng kỹ thuật nhỏ, WoT gặp phải vấn đề lớn về "bootstrapping" (khó khăn cho người mới tham gia để có được sự tin cậy) và tính thân thiện với người dùng thông thường, do đó không thể mở rộng ở quy mô toàn cầu.

3.1.5 Hierarchical PKI

Đây là mô hình phổ biến và thành công nhất hiện nay trên Internet. Hierarchical PKI sử dụng cấu trúc cây phân cấp dựa trên nguyên tắc "tin cậy bắc cầu" (transitive trust). Sự tin cậy được kế thừa từ các Root CA (Tổ chức phát hành chứng chỉ gốc) trên cùng, truyền xuống các Intermediate CA, và cuối cùng đến các chứng chỉ thực thể (Leaf certificates). Ở phía máy khách, hệ điều hành và trình duyệt (như Mozilla NSS, Microsoft, Apple) duy trì một kho lưu trữ chứng chỉ gốc đáng tin cậy (Trust Store). Hoạt động của các CA này được quản lý và tiêu chuẩn hóa thông qua các yêu cầu cơ sở (baseline requirements) do CA/Browser Forum [2] ban hành.

3.1.6 So sánh trade-off

Sự khác biệt giữa các mô hình chủ yếu nằm ở cách tiếp cận quản lý sự tin cậy. Mô hình phân cấp (Hierarchical) có ưu điểm là dễ dàng kiểm toán (audit) và thu hồi chứng chỉ

(revoke), quản lý thống nhất, nhưng lại biến các Root CA thành những điểm yếu chí mạng (Single Point of Failure - SPOF) về mặt tin cậy. Ngược lại, mô hình phi tập trung như Web of Trust không có SPOF, nhưng quá trình đánh giá niềm tin lại không đủ tính bắc cầu mạnh mẽ và quá phức tạp đối với người dùng phổ thông.

Table 3.1: So sánh các mô hình tin cậy (Trust Models)

Tiêu chí	Hierarchical PKI (Centralized)	Web of Trust (Decentralized)
Cấu trúc	Cây phân cấp từ Root CA xuống Leaf	Mạng lưới đồng đẳng (Peer-to-peer)
Quản lý thu hồi	Dễ dàng, quản lý tập trung (CRL/OCSP)	Khó khăn, phụ thuộc vào bản cập nhật của từng node
Rủi ro (SPOF)	Root CA bị xâm nhập là thảm họa	Không có SPOF rõ rệt
Tính thân thiện	Rất cao (trong suốt với người dùng)	Thấp (đòi hỏi kiến thức kỹ thuật)

3.2 Định nghĩa và mục tiêu PKI

Như đã đề cập, Hạ tầng khóa công khai (PKI) là một bộ khung bao gồm các thành phần công nghệ (phần cứng, phần mềm), cơ cấu tổ chức (con người), và các tài liệu điều chỉnh (chính sách, quy trình) nhằm mục đích phát hành, duy trì, và thu hồi các chứng chỉ số số trong một môi trường mạng mở.

Mục tiêu lớn nhất của PKI là giải quyết bài toán cốt lõi về "sự tin cậy" (trust) trên môi trường số bằng cách cung cấp một cơ chế bảo đảm để gắn kết (bind) một danh tính thực (một con người, một tổ chức, hoặc một thiết bị) với một khóa công khai cụ thể thông qua bên thứ ba được tin tưởng là CA. Quan trọng hơn, PKI không chỉ dừng lại ở các giao thức kỹ thuật, mà nó mang đậm tính chất quản trị (governance) – giải quyết các vấn đề vĩ mô như: ai có đủ thẩm quyền để làm CA? Tiêu chuẩn nào CA phải tuân thủ để được đưa vào Trust Store của các trình duyệt?

****Ứng dụng của public key: Chữ ký số**** Sau khi PKI đã thiết lập sự tin cậy trong khóa công khai của một thực thể (thông qua việc cấp chứng chỉ số), thực thể đó có thể sử dụng cặp khóa của mình để đạt được các mục tiêu an toàn thông tin cụ thể, như được minh họa trong Hình 3.1. Sơ đồ này cho thấy quy trình tạo và xác thực chữ ký số, giúp đảm bảo tính toàn vẹn (Integrity) và tính xác thực (Authentication) của thông điệp được truyền đi.

Sử dụng khóa bí mật (Private Key) để ký số lên hàm băm (Message Digest) tạo ra một bằng chứng không thể phủ nhận về nguồn gốc của thông điệp. Khi người nhận dùng khóa công khai tương ứng để xác thực thành công, họ biết chắc rằng thông điệp thực sự đến từ chủ sở hữu khóa và không bị chỉnh sửa trên đường truyền. Đây chính là một trong

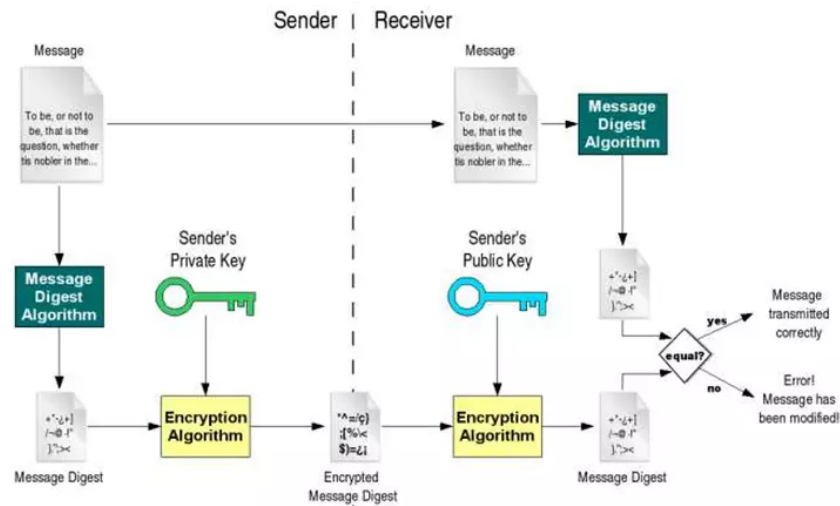


Figure 3.1: Quy trình tạo và xác thực chữ ký số sử dụng cặp khóa công khai và bí mật.

những mục tiêu hoạt động then chốt mà PKI hướng tới nhằm tạo ra sự tin cậy tổng thể.

3.3 Các thành phần PKI

CA – Certificate Authority

Certificate Authority (Tổ chức phát hành chứng chỉ) là trái tim của hệ thống PKI. CA chịu trách nhiệm chính trong việc phát hành, thu hồi chứng chỉ và duy trì danh sách chứng chỉ bị thu hồi (CRL). Để tối ưu hóa tính bảo mật, các CA thường được tổ chức theo cấu trúc phân tầng. Trên cùng là Root CA, nắm giữ khóa quan trọng nhất và thường được giữ ở trạng thái ngoại tuyến (offline, air-gapped) để tránh bị tấn công mạng. Root CA ký cấp phát chứng chỉ cho các Intermediate CA (CA trung gian), và các Intermediate CA này mới là đơn vị trực tiếp tương tác và cấp phát chứng chỉ cho thực thể cuối (Leaf/End-entity). Quy trình cơ bản bao gồm: người dùng tạo Yêu cầu ký chứng chỉ (CSR) → CA xác minh danh tính → CA dùng khóa bí mật để ký chứng chỉ → Công bố chứng chỉ.

RA – Registration Authority

Registration Authority (Tổ chức đăng ký) hoạt động như một cơ quan tiền phương cho CA. Việc tách bạch quá trình xác minh danh tính (thực hiện bởi RA) khỏi quá trình ký chứng chỉ (thực hiện bởi CA) giúp phân quyền trách nhiệm và giảm thiểu rủi ro bảo mật cho hệ thống ký. RA đóng vai trò kiểm tra tính hợp lệ của người nộp đơn. Ví dụ trong thực tế, RA có thể yêu cầu người dùng xuất trình Căn cước công dân hoặc Hộ chiếu để đối chiếu; sau khi RA xác nhận hợp lệ, yêu cầu mới được chuyển tiếp để CA thực hiện thao tác ký số sinh ra chứng chỉ.

Repository – Kho lưu trữ chứng chỉ

Kho lưu trữ (Repository) là cơ sở dữ liệu công khai lưu trữ các chứng chỉ đang có hiệu lực và danh sách các chứng chỉ đã bị thu hồi. Kho này thường được triển khai trên các máy chủ thư mục LDAP (Lightweight Directory Access Protocol) hoặc máy chủ HTTP/HTTPS, đảm bảo các client có thể truy vấn nhanh chóng để lấy chứng chỉ của người cần giao tiếp hoặc kiểm tra trạng thái CRL bất cứ lúc nào.

CRL – Certificate Revocation List

Danh sách chứng chỉ bị thu hồi (CRL) là một tài liệu được CA ký số và phát hành định kỳ, liệt kê số seri của các chứng chỉ đã bị mất hiệu lực trước khi hết hạn. Các lý do thu hồi (reason codes) thường được đi kèm, ví dụ như lộ khóa bí mật (`keyCompromise`) hoặc bản thân CA bị xâm phạm (`cACompromise`). Hạn chế lớn của CRL là kích thước tệp có thể phình to rất nhanh và thông tin không được cập nhật tức thời (có thể lỗi thời - stale trong nhiều giờ hoặc vài ngày trước khi bản mới được tải về). Để giảm tải mạng, giải pháp `delta CRL` [3] được sử dụng để chỉ tải xuống những thay đổi so với bản CRL đầy đủ trước đó.

OCSP – Online Certificate Status Protocol

Giao thức kiểm tra trạng thái chứng chỉ trực tuyến (OCSP) [4] ra đời nhằm khắc phục độ trễ của CRL. Thay vì tải toàn bộ danh sách, client gửi truy vấn chứa số seri của chứng chỉ đến máy chủ OCSP Responder và nhận về phản hồi theo thời gian thực (Realtime) về trạng thái hợp lệ của chứng chỉ đó. Để giải quyết vấn đề về quyền riêng tư (vì CA biết client đang truy cập trang web nào) và độ trễ (latency) khi client phải tự liên hệ CA, kỹ thuật **OCSP Stapling** [5] được áp dụng. Máy chủ web sẽ tự động lấy (pre-fetch) phản hồi OCSP có chữ ký của CA theo định kỳ, sau đó "gắn kèm" (staple) bằng chứng này vào quá trình thiết lập kết nối TLS ban đầu với client.

Table 3.2: So sánh các phương pháp kiểm tra trạng thái thu hồi chứng chỉ

Tiêu chí	CRL	OCSP	OCSP Stapling
Độ trễ cập nhật	Cao (phụ thuộc chu kỳ tải)	Thấp (thời gian thực)	Thấp (thời gian thực, có cache)
Chi phí băng thông	Rất cao (tải toàn bộ list)	Thấp	Rất thấp
Quyền riêng tư	Tốt (Client kiểm tra cục bộ)	Kém (CA biết lịch sử duyệt web)	Tốt (Client không gọi trực tiếp CA)

3.4 Chu kỳ sống của chứng chỉ

Hoạt động của PKI phụ thuộc vào việc quản lý chặt chẽ vòng đời (lifecycle) của một chứng chỉ số. Chu kỳ sống này bao gồm các giai đoạn tuần tự:

1. **Tạo cặp khóa (Keypair Generation):** Thực thể tự tạo Khóa công khai và Khóa bí mật một cách an toàn.
2. **Tạo yêu cầu (CSR Creation):** Gói Khóa công khai và các thông tin định danh vào một bản tin CSR (Certificate Signing Request).
3. **Xác minh (Verification):** RA/CA kiểm tra tính hợp lệ của thông tin và quyền sở hữu tên miền/tổ chức.
4. **Phát hành (Issuance):** CA ký điện tử lên CSR để tạo ra chứng chỉ số hợp lệ.
5. **Sử dụng (Usage):** Chứng chỉ được triển khai trên hệ thống (web server, email) để thực hiện mã hóa và xác thực.
6. **Gia hạn / Thu hồi (Renewal / Revocation):** Trước khi hết hạn, chứng chỉ cần được gia hạn. Nếu khóa bí mật bị lộ hoặc thông tin không còn đúng, chứng chỉ sẽ bị đưa vào quá trình thu hồi (đưa vào CRL hoặc báo trạng thái qua OCSP).

Với sự bùng nổ của quy mô dịch vụ đám mây và microservices, việc cấu hình thủ công không còn khả thi. Tự động hóa vòng đời chứng chỉ (Certificate Lifecycle Automation) thông qua các giao thức như ACME (được Let's Encrypt sử dụng phổ biến), SCEP, hoặc EST ngày càng đóng vai trò quan trọng yếu giúp đảm bảo hệ thống không bị gián đoạn dịch vụ do chứng chỉ hết hạn.

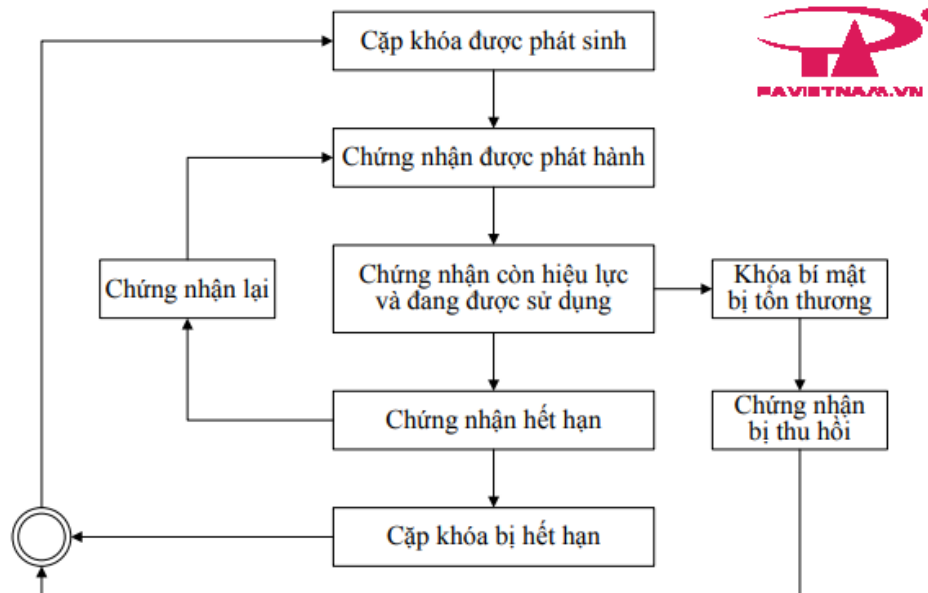


Figure 3.2: Sơ đồ chu kỳ sống của chứng chỉ số trong hệ thống PKI

Chapter 4

Chứng chỉ số và các chuẩn

4.1 Chứng chỉ số X.509

Lịch sử và phiên bản

Cấu trúc X.509 v3

Distinguished Name (DN)

Extensions quan trọng

4.2 Certificate Signing Request (CSR)

4.3 Phân loại chứng chỉ

Theo mức độ xác minh danh tính

Theo phạm vi tên miền

4.4 Các chuẩn PKCS

4.5 RFC và chuẩn quan trọng

Chapter 5

Triển khai và ứng dụng thực tế

5.1 HTTPS / TLS

Lịch sử SSL đến TLS 1.3

TLS Handshake và xác minh chứng chỉ

Cải tiến trong TLS 1.3

5.2 Chữ ký số văn bản điện tử

Nguyên lý ký số văn bản

Khung pháp lý tại Việt Nam

CA nhà nước Việt Nam

5.3 S/MIME – Email bảo mật

5.4 VPN và IPSec

5.5 Code Signing

5.6 PKI trong eGovernment Việt Nam

Chapter 6

Các hệ thống PKI mã nguồn mở

6.1 OpenSSL

Tổng quan OpenSSL

Xây dựng CA đơn giản với OpenSSL

6.2 EJBCA

6.3 Let's Encrypt và Certbot

Let's Encrypt và sứ mệnh

ACME Protocol và Certbot

6.4 Các công cụ và nền tảng khác

XCA

HashiCorp Vault PKI Secrets Engine

CFSSL (Cloudflare)

Dogtag / FreeIPA (Red Hat)

Chapter 7

Thách thức và xu hướng

7.1 Thách thức hiện tại

CA Compromise — bài học từ DigiNotar và Symantec

Certificate Transparency (CT) như giải pháp giám sát

Quản lý vòng đời chứng chỉ

PKI cho IoT

7.2 Xu hướng mới

Post-Quantum PKI

Tự động hoá và rút ngắn thời hạn chứng chỉ

Decentralized Identity (DID)

Chapter 8

Kết luận

8.1 Tổng kết

8.2 Ý nghĩa và triển vọng

Tài liệu tham khảo

- [1] P. R. Zimmermann, *PGP: Source code and internals*, 1995.
- [2] CA/Browser Forum, *Baseline requirements for the issuance and management of publicly-trusted certificates*, 2023. [Online]. Available: <https://cabforum.org/baseline-requirements-documents/>
- [3] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk, “Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile,” IETF, RFC 5280, 2008. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc5280>
- [4] S. Santesson, M. Myers, R. Ankney, A. Malpani, S. Galperin, and C. Adams, “X.509 Internet Public Key Infrastructure Online Certificate Status Protocol – OCSP,” IETF, RFC 6960, 2013. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6960>
- [5] D. E. 3rd, “Transport Layer Security (TLS) Extensions: Extension Definitions,” IETF, RFC 6066, 2011, Section 8: Certificate Status Request (OCSP Stapling). [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6066>